

Response to Smart Contract Technical Review – Task 2

We appreciate the additional review and the detailed feedback provided. The comments are constructive and align with our goal of building a robust, secure, and scalable AmnestyDAO token system. Below is a point-by-point response outlining our current coverage, planned mitigations, and next steps.

1. Data Model & Serialization

Audit: Dict types not serializable; risk of non-deterministic key ordering.

Response: While not currently an issue for our codebase it is good to be made aware of this. We will ensure to prioritise deterministic `List<Pair<ByteArray, Int>>` for on-chain representations over `Dict` types. Aiken's standard library now supports deterministic map reconstruction, which will prevent hash mismatch errors. Sorting functions will be added to test utilities to ensure key order consistency.

2. Incentive Logic & Token Categorization

Audit: Current tokens are fungible; category tracking not enforced.

Response: This was beyond the Milestone 2 scope but the recommendation to adopt category-specific mint policies (e.g., `HRT:EDU`, `HRT:HLT`) using CIP-68 metadata tagging, enabling differentiated rewards will be considered in future implementations.

3. Faucet Abuse & Sybil Resistance

Audit: Signup reward vulnerable to Sybil attack.

Response: Also beyond the scope for the pilot application but we acknowledge this risk and plan to integrate a proof-of-personhood model, leveraging an identity registry and rate-limiting on the backend. This will ensure each verified user can only receive one initial reward.

4. Access Control & Mint Policy Governance

Audit: Single-key minting poses risk.

Response: Agreed this is already a known risk with governance control multi-sig minting architecture to replace the single-key model in the next iteration. A `k-of-m` multisig policy with

time-lock and **emergency pause** parameters will be implemented. Keys will be managed via an **Oracle Registry** to allow rotation and recovery without redeploying contracts.

5. Replay / Double-Spend / Nonce Management

Audit: Missing nonce validation.

Response: We will introduce a **nonce registry UTxO** tracked by each oracle-verified transaction. Each claim will include a nonce in the redeemer, checked and consumed during validation to prevent replay or double-claim attacks.

6. State Growth & Concurrency

Audit: Single UTxO accumulation risk and concurrency limits.

Response: This needs some further investigation before global deployment but is out of scope of the pilot deployment.

7. Arithmetic & Merge Strategy

Audit: Possible overflow or negative balances.

Response: Future arithmetic operations will use safe clamping (`max(0, value)`) and explicit type bounds.

8. Front-Running & Transaction Binding

Audit: Outputs could be modified pre-confirmation.

Response: The next revision will **bind output and datum hashes in redeemers**, and we will implement a **commit–reveal pattern** for oracle-based reward claims. This prevents adversaries from altering transaction details between submission and confirmation.

9. Governance Layer

Audit: One-token-one-vote risk of governance capture.

Response: Governance design is under active development. We intend to integrate **quadratic voting**, **minimum quorum requirements**, and **veto/staging mechanisms** within the DAO's governance smart contracts to promote fair participation and safeguard against token concentration.

10. Compliance & Recovery

Audit: Lost keys = unrecoverable tokens.

Response: This is a deliberate design tradeoff under review. We are investigating a controlled recovery process through multisig-authorized reissuance for verified users who lose keys, balanced against immutability and accountability requirements.

11. Continuous Integration & Testing

Audit: CI lacks property/fuzz testing.

Response: Current tests already include property-based tests and adversarial simulations using randomized redeemers and mock transactions. We will add the relevant CI hooks in the next milestone for the project.

12. Scalability & Global Readiness

Audit: Base-layer throughput insufficient for global scale.

Response: Agreed but scaling will be addressed in next iteration and beyond through:

- **Batch oracle aggregation** for settlement,
- **Hydra heads** for parallel execution, and
- **Mithril snapshots** for state verification and lightweight replication.
Preliminary execution-unit analysis already confirms low per-transaction cost, indicating readiness for Hydra migration.

Conclusion

We acknowledge and appreciate the audit's comprehensive review. The feedback highlights important next steps for hardening the system before global rollout. All identified issues are resolvable within Aiken/Plutus V2, and work is already planned or in progress to address many of them. The current contracts remain fit for purpose as a secure proof-of-concept for AmnestyDAO's membership and reward system, with clear upgrade paths toward full-scale deployment.